1 Inhaltsverzeichnisidee

1. Einleitung
    - Relevanz
        - Darstellung der fortschreitenden Digitalisierung der Finanzmärkte
        - Aufstieg von Neobrokern
        - Bedeutung für Privatanleger und die private Altersvorsorge
    - Motivation
        - Lücke zwischen einfachem Handel und komplexer Marktanalyse
        - Entwicklung einer Plattform, die Benutzerfreundlichkeit und analytische Tiefe vereint
    - Problemraumbeschreibung
        - Um was geht es?
        - Was löst es für ein Problem?
        - Was soll zum Schluss rauskommen?
    - Umgebung/Schnittstellen
        - Überblick über die technische und organisatorische Umgebung des Projekts.
            * verwendete Technologien
            * API-Schnittstellen
                · Marktdaten
                · Nachrichtendienste
                · Broker-APIs

2. Strukturierte Aufgabenstellung
    - Konkretisierung der Projektziele in überprüfbare Arbeitsschritte:
        - Von der Analyse bestehender Lösungen über die Konzeption bis hin zur technischen Umsetzung.
    - Strukturierung des Projektablaufs in Phasen
        - Analyse, Entwurf, Implementierung, Test, Evaluation
    - Beschreibung der Abhängigkeiten und Prioritäten.
    - Definition von Bewertungskriterien zur Überprüfung der Zielerreichung.
        - (z. B. Usability, Funktionalität, Performanz)
3. Methoden und Verfahren
    - Beschreibung der eingesetzten Frameworks, Programmiersprachen, APIs und Datenquellen.
        - z. B. Python für Analysen, REST-APIs, React/Laravel-Frontend, Docker-Containerisierung etc.
    - Einsatz von Git-basiertem Versionsmanagement. Versionsnummern und Änderungsverfolgung als Bestandteil der Qualitätssicherung
    - Auswahl und Begründung des gewählten agilen Vorgehensmodells (z. B. Scrum oder Kanban). Erläuterung der Rollen, Iterationen und Kommunikationswege.
    - SEHR WICHTIG ÜBERALL DATUM UND VERRSIONIERUNG NOTIEREN!
    - Beschreibung der eingesetzten Frameworks, Programmiersprachen, APIs und Datenquellen.
4. Theoretische und Technische Grundlagen
    - Grundlagen des Aktienmarktes und Handelsmechanismen

- Neobroker und klassische Broker im Vergleich
- State of the Art mit ausgewählten Plattformen aka was gibt es auf dem Markt (z. B. Trade Republic, Scalable Capital, eToro, Interactive Brokers, JustTrade)
- Algorithmen welche zur Umsetzung genutzt wurden
- Grundlagen welche zur Entwicklung genutzt wurden
- Sekundär literarur empfehlungen gerne gesehen!!

5. Bearbeitung der strukturierten Aufgabenstellung
   - Detaillierte Beschreibung der einzelnen Entwicklungsschritte gemäß des in Kapitel 2 definierten Plans.
6. Objektivierter Ergebnisteil
   - Tabellarische Gegenüberstellung: geplante vs. erreichte Funktionen, technische und funktionale Erfolgsbewertung.
   - Bewertung nach festgelegten Maßstäben (Usability, Stabilität, Datenaktualität, Performanz) (unbedingt Bewertung anhand eines offiziellen Charts, keine eigenen Kriterien definieren)
   - Vergleich von bestehenden Lösungen und eigener Lösung
7. Diskussion (manchmal auch Fazit oder kritische Reflexion)
   - Subjektivierung der Arbeitsergebnisse
   - Was lief gut und was lief schlecht?
8. Ausblick
   - Perspektiven für zukünftige Versionen des Systems
   - Was könnte man sich sonst noch so anschauen?
9. Literaturverzeichnis

10. Glossar

11. Anhang

2 Relevanz

Die fortschreitende Digitalisierung und der Aufstieg von Neobrokern haben den Zugang zum Aktienmarkt deutlich verändert. Durch technologische Innovationen, automatisierte Prozesse und benutzerfreundliche mobile Anwendungen ist Investieren heute so einfach, kostengünstig und barrierearm wie nie zuvor. Mit wenigen Klicks können Menschen weltweit an der Entwicklung der Finanzmärkte teilhaben und ihre persönliche Vermögensbildung aktiv gestalten. Dieser erleichterte Zugang hat zu einer deutlichen Demokratisierung des Investierens geführt und neue Anlegergruppen erschlossen, die zuvor aufgrund hoher Gebühren, komplexer Strukturen oder mangelnder Informationsangebote kaum Berührungspunkte mit dem Kapitalmarkt hatten. Besonders im Kontext der privaten Altersvorsorge gewinnt dieses Thema zunehmend an Bedeutung, da traditionelle Anlageformen aufgrund niedriger Zinsen und wirtschaftlicher Unsicherheiten an Attraktivität verloren haben. Die Kombination aus einfachen Einstiegsmöglichkeiten, geringen Transaktionskosten und hoher Transparenz unterstreicht die zunehmende Bedeutung digitaler Investmentplattformen im Rahmen moderner Vermögensbildung.

So zeigt auch eine Erhebung des Deutschen Instituts für Vermögensbildung und Alterssicherung (DIVA), dass die Verbreitung von Wertpapierdepots in der Bevölkerung ein beachtliches Niveau erreicht hat: Mehr als die Hälfte der Befragten (51,7 %) verfügt demnach über ein oder mehrere Depots, wobei 43,0 % dieser Personen (auch) einen Neobroker nutzen. Besonders auffällig ist die überdurchschnittlich hohe Nutzung digitaler Broker in den jüngeren Altersgruppen: 59,1 % der unter 29-Jährigen und 58,1 % der unter 49-Jährigen greifen auf entsprechende Angebote zurück.

Ein Blick auf die Zeitreihe der Deutschen Bundesbank verdeutlicht klar die Dynamik dieser Entwicklung. Die Grafik zeigt, dass die Zahl der Wertpapierdepots privater Haushalte über viele Jahre relativ stabil blieb und sogar leicht rückläufig war. Erst ab 2019 setzt ein deutlicher struktureller Wandel ein, der sich ab 2020 weiter beschleunigt. Dieser Anstieg fällt zeitlich sowohl mit der Einführung moderner Neobroker wie Trade Republic (2019) und Scalable Capital (2020) als auch mit den Bedingungen der Corona-Pandemie zusammen. Während die Pandemie durch vermehrte digitale Aktivitäten und ein gestiegenes Interesse an privater Finanzplanung eine zusätzliche

Verstärkung bewirkte, reduzierten die Neobroker gleichzeitig erheblich die Hürden für den Kapitalmarktzugang. Insbesondere die Kombination aus intuitiven Apps, sehr niedrigen oder vollständig entfallenden Ordergebühren und einem stark vereinfachten Onboarding-Prozess dürfte dazu beigetragen haben, dass Millionen neuer Anleger erstmals ein Depot eröffneten. Die Grafik belegt daher nicht nur einen kurzfristigen Effekt, sondern markiert einen strukturellen Wandel in der Anlegerkultur Deutschlands. Trotz dieser positiven Entwicklung bleibt jedoch eine entscheidende Lücke bestehen: Während der Handel selbst inzwischen weitgehend vereinfacht und automatisiert ist, mangelt es an integrierten, benutzerfreundlichen Lösungen für eine fundierte Marktanalyse. Bestehende Anwendungen beschränken sich häufig auf Basisfunktionen oder liefern Informationen nur in Fragmenten – beispielsweise über Kursentwicklungen, Unternehmensdaten oder Nachrichtenfeeds. Eine tiefgehende, ganzheitliche Analyse des Marktes, die verschiedene Informationsquellen zusammenführt und verständlich aufbereitet, ist für Privatanleger nach wie vor schwer zugänglich.

Hinzu kommt, dass viele Privatanleger erst dann von relevanten Marktbewegungen oder wirtschaftlichen Trends erfahren, wenn die entscheidenden Gewinne bereits realisiert wurden. Die Informationsflut ist groß, aber verstreut und oft nur mit erheblichem Zeitaufwand zu durchdringen. Dies erschwert es insbesondere Einsteigern, aber auch erfahrenen Anlegern, informierte und strategisch durchdachte Entscheidungen zu treffen.

3 Motivation

Die zunehmende Verbreitung digitaler Investmentplattformen hat den Zugang zum Aktienhandel erheblich vereinfacht, während professionelle Marktanalysen weiterhin nur über komplexe und oft schwer zugängliche Spezialwerkzeuge verfügbar sind. Dadurch entsteht eine deutliche Lücke zwischen intuitiven Handels-Apps und anspruchsvollen Analyseumgebungen, die viele Privatanleger vor Herausforderungen stellt. Diese Diskrepanz bildet die zentrale Motivation des vorliegenden Projekts. Ziel ist es, eine Plattform zu entwickeln, die Benutzerfreundlichkeit mit analytischer Tiefe verbindet und es Nutzerinnen und Nutzern ermöglicht, fundierte Informationen ohne technische oder fachliche Barrieren zu nutzen. Durch verständliche Visualisierungen, strukturierte Datenaufbereitung und nachvollziehbare Analyseprozesse soll eine Anwendung entstehen, die sowohl den Handel effizienter gestaltet als auch langfristig zur finanziellen Bildung beiträgt. Die Plattform soll damit eine Brücke zwischen Einsteigerfreundlichkeit und professioneller Marktanalyse schlagen und Anlegerinnen und Anleger in ihrer selbstbestimmten Vermögensplanung unterstützen.

4 Problemraumbeschreibung

Der vorliegende Problemraum betrifft eine wachsende Gruppe von Akteuren, die in besonderem Maße von der Digitalisierung des Wertpapierhandels beeinflusst wird. Dazu zählen vor allem junge Menschen und Neuanleger, die erstmals Zugang zum Aktienmarkt erhalten, ebenso wie Personen aus bildungsferneren Schichten, die aufgrund sprachlicher oder didaktischer Barrieren Schwierigkeiten haben, komplexe Finanzinformationen zu verstehen. Auch Nutzerinnen und Nutzer mit praktischer Tradingerfahrung, jedoch ohne tiefere finanzwirtschaftliche Kenntnisse, sind betroffen, da sie zwar bereits handeln, aber häufig keine ausreichende fachliche Grundlage besitzen. Darüber hinaus stellt die zunehmende Digitalisierung ältere Generationen vor zusätzliche Herausforderungen, weil fehlende digitale Kompetenz die Nutzung moderner Handelsanwendungen erschwert.

Trotz der hohen Verfügbarkeit leicht zugänglicher Handelsplattformen bestehen erhebliche Defizite im Bereich der Wissensvermittlung, Analyseunterstützung und Transparenz. Während Neobroker den Zugang zum Markt stark erleichtern, bleibt der Zugang zu qualitativ hochwertigen Informationen, Analysewerkzeugen und Bildungsinhalten vielerorts eingeschränkt oder ist an kostenpflichtige Angebote gebunden, die für bestimmte Bevölkerungsgruppen nicht zumutbar sind. Es entsteht ein struktureller Widerspruch: Einerseits werden breite Bevölkerungsschichten zum Investieren ermutigt – oftmals durch intensive Marketingkampagnen mit hohen Gewinnversprechen und minimalen Risikohinweisen –, andererseits fehlt es diesen Nutzergruppen an den notwendigen Instrumenten und Kompetenzen, um fundierte Entscheidungen zu treffen. Diese Diskrepanz verschärft bestehende Ungleichheiten, denn während der Zugang zum Markt technisch niedrigschwellig ist, bleibt der Zugang zu Wissen und Analysefähigkeit weiterhin hochschwellig. Die Folge ist nicht selten ein Investitionsverhalten, das von Trends, Emotionen oder Fehlinformationen geprägt ist, was wiederum zu finanziellen Verlusten führt – ein Umstand, von dem Plattformbetreiber aufgrund gebührenbasierter Geschäftsmodelle indirekt sogar profitieren können.

Nachweisbare Lücken zeigen sich insbesondere in der fehlenden Integration von Bildungs- und Analysefunktionen innerhalb bestehender Brokerage-Anwendungen, in der unzureichenden Aufbereitung komplexer Finanzdaten sowie in der mangelnden Unterstützung

bei der Einschätzung von Risiken. Während professionelle Analysewerkzeuge zwar existieren, sind sie häufig teuer, technisch anspruchsvoll oder für Einsteiger unverständlich aufbereitet. Damit bleibt ein wesentlicher Aspekt ungeklärt: Wie kann finanzwirtschaftliches Fachwissen so vermittelt und Analysefunktionen so bereitgestellt werden, dass sie unterschiedlichen gesellschaftlichen Milieus zugänglich sind, ohne dass hohe Kosten oder technische Hürden entstehen? Ebenso stellt sich die Frage, wie bestehende Plattformmodelle, die primär auf Umsatzgenerierung ausgerichtet sind, so transformiert werden können, dass sie neben der Bedienfreundlichkeit auch echte finanzielle Aufklärung ermöglichen. Aus diesem Problemfeld ergibt sich ein übergeordnetes Ziel: die Entwicklung eines Systems, das den einfachen Zugang zum Investieren mit qualifizierten, verständlichen und zugleich leistungsfähigen Analyse- und Bildungswerkzeugen verbindet. Das Projekt trägt dazu bei, die bestehenden Schwierigkeiten zwischen erfahrungsarmen Einsteigern und professionellen Marktteilnehmern besser zu verstehen und Lösungen zu entwickeln, die diese Lücke nachhaltig schließen. Trotz der niedrigen Einstiegshürden im modernen Aktienhandel besteht weiterhin das Problem des informierten Investierens, da viele Anbieter ihre Nutzerinnen und Nutzer weder ausreichend aufklären noch ihnen die Werkzeuge zur Verfügung stellen, die sie für fundierte Entscheidungen benötigen. Die geplante Anwendung setzt genau hier an: Sie zielt darauf ab, Nutzer durch integrierte Analysefunktionen, hochwertige Informationsmaterialien und intuitive Risikobewertungen zu befähigen, auf Basis von Wissen und nicht aufgrund von Intuition oder Marktgeräuschen zu handeln. Langfristig soll so ein nutzerzentriertes, transparentes und aufklärungsorientiertes System entstehen, das die bestehenden Defizite im Bereich Bildung, Informationszugang und Entscheidungsunterstützung adressiert und einen Beitrag zu einem nachhaltigeren und verantwortungsvolleren Anlegerverhalten leistet.

5 Epics

5.1 Epic 1: Core Functions

Ziel:
Ziel dieses Epics ist die Bereitstellung der zentralen fachlichen Analyse- und Informationsfunktionen der Plattform, welche Nutzern die strukturierte Auswertung von Finanz-, Markt- und Makrodaten ermöglichen. Hierzu zählen unter anderem Portfolio- und Marktdatenanalysen, die Integration externer Nachrichten- und Sentimentquellen sowie verschiedene fundamentale, technische und quantitative Analyseverfahren. Die Umsetzung dieser Kernfunktionen erfolgt unter Berücksichtigung definierter Sicherheits-, Datenschutz- und Integritätsanforderungen, um einen kontrollierten Zugriff auf sensible Informationen, die Korrektheit der zugrunde liegenden Daten sowie die Nachvollziehbarkeit sicherheitsrelevanter Aktionen sicherzustellen.

EPIC 1: Core Functions

Fokus:
Portfoliomanagement (FA-1.1),
Marktdaten (FA-1.2),
Nachrichten & Sentiment (FA-1.3),
Fundamentalanalyse (FA-1.4),
Alerts & Benachrichtigungen (FA-1.5),
Technische Analyse (FA-1.6),
Quantitative Analyse & Screening (FA-1.7),
Makro & Marktumfeld (FA-1.8)

5.1.1 FA-1.1 Portfoliomanagement

Beschreibung:
Das System ermöglicht Benutzern die Anlage, Anzeige und Verwaltung individueller Portfolios einschließlich enthaltener Positionen, aggregierter Kennzahlen sowie historischer Wertentwicklungen.

Umfang:

- Erstellung, Bearbeitung und Löschung von Portfolios
- Anzeige enthaltener Positionen und deren Gewichtungen
- Darstellung historischer Performance- und Wertentwicklungen

Erfüllungskriterien (EK):

- **EK-1.1.1**: Ein authentifizierter Benutzer kann ausschließlich seine eigenen Portfolios anzeigen.
- **EK-1.1.2**: Änderungen an Portfolios werden persistent gespeichert und sind konsistent abrufbar.
- **EK-1.1.3**: Historische Wertentwicklungen werden vollständig und korrekt dargestellt.
- **EK-1.1.4**: Unautorisierte Zugriffsversuche werden serverseitig verhindert.
- **EK-1.1.5**: Erstellungs-, Änderungs- und Löschvorgänge werden nachvollziehbar protokolliert.

Relevante Security Requirements:

- **SR-2** – Autorisierung und Zugriffskontrolle *(Information Disclosure)*
- **SR-3** – Schutz personenbezogener Daten *(Information Disclosure)*
- **SR-5** – Sicherstellung der Datenintegrität *(Tampering)*
- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*

5.1.2 FA-1.2 Marktdaten

Beschreibung:
Das System ruft aktuelle und historische Marktdaten aus externen Datenquellen ab, verarbeitet diese und stellt diese Benutzern in aufbereiteter Form zur Verfügung.

Umfang:

- Abruf von Kurs- und Zeitreihendaten
- Normalisierung und Zwischenspeicherung der Marktdaten
- Aktualisierung der Daten in definierten Intervallen

Erfüllungskriterien (EK):

- **EK-1.2.1**: Marktdaten werden ausschließlich aus definierten externen Quellen bezogen.
- **EK-1.2.2**: Eingehende Marktdaten werden vor der Verarbeitung validiert.
- **EK-1.2.3**: Das System bleibt bei temporärem Ausfall einer externen Datenquelle funktionsfähig.
- **EK-1.2.4**: Abrufe von Marktdaten unterliegen technischen Zugriffsbeschränkungen.
- **EK-1.2.5**: Fehler beim Abruf oder der Verarbeitung von Marktdaten werden intern protokolliert.

Relevante Security Requirements:

- **SR-5** – Sicherstellung der Datenintegrität *(Tampering)*
- **SR-6** – Absicherung externer Schnittstellen *(Tampering, Denial of Service)*
- **SR-7** – Schutz vor Missbrauch *(Denial of Service)*
- **SR-10** – Sicherstellung der Verfügbarkeit *(Denial of Service)*

5.1.3 FA-1.3 Nachrichten & Sentiment

Beschreibung:
Das System integriert Nachrichten- und Sentimentdaten aus externen Quellen und stellt diese kontextbezogen zu Finanzinstrumenten und relevanten Märkten dar.

Umfang:

- Anzeige relevanter Nachrichten zu Finanzinstrumenten und Märkten
- Aggregierte Sentiment-Bewertungen aus externen Datenquellen
- Filterung der Inhalte nach Themen, Märkten und Assets

Erfüllungskriterien (EK):

- **EK-1.3.1**: Nachrichten- und Sentimentdaten werden ausschließlich aus validierten externen Quellen bezogen.
- **EK-1.3.2**: Externe Inhalte werden vor der Darstellung technisch geprüft.
- **EK-1.3.3**: Die Anzeige erfolgt kontextbezogen zu ausgewählten Finanzinstrumenten und Assets.
- **EK-1.3.4**: Externe Inhalte führen nicht zur Offenlegung interner Systeminformationen.

Relevante Security Requirements:

- **SR-6** – Absicherung externer Schnittstellen *(Tampering)*
- **SR-7** – Schutz vor Missbrauch *(Denial of Service)*
- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.1.4 FA-1.4 Fundamentalanalyse

Beschreibung:
Das System berechnet und visualisiert fundamentale Kennzahlen zu Finanzinstrumenten auf Basis externer und interner Daten.

Umfang:

- Berechnung fundamentaler Kennzahlen
- Historische Vergleiche fundamentaler Kennzahlen
- Darstellung der Ergebnisse in Tabellen und Diagrammen

Erfüllungskriterien (EK):

- **EK-1.4.1**: Fundamentale Kennzahlen werden konsistent berechnet.
- **EK-1.4.2**: Berechnungsergebnisse sind reproduzierbar.
- **EK-1.4.3**: Ergebnisse werden vollständig und verständlich dargestellt.
- **EK-1.4.4**: Fehlerhafte Eingangsdaten führen nicht zu inkonsistenten Ergebnissen.

Relevante Security Requirements:

- **SR-5** – Sicherstellung der Datenintegrität *(Tampering)*
- **SR-10** – Sicherstellung der Verfügbarkeit *(Denial of Service)*
- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*

5.1.5 FA-1.5 Alerts & Benachrichtigungen

Beschreibung:
Das System ermöglicht die Konfiguration benutzerdefinierter Schwellenwerte und Bedingungen, bei deren Erfüllung systeminterne Benachrichtigungen ausgelöst werden.

Umfang:

- Definition benutzerindividueller Alert-Regeln
- Verwaltung bestehender Alerts
- Auslösung systeminterner Benachrichtigungen

Erfüllungskriterien (EK):

- **EK-1.5.1**: Benutzer können Alerts ausschließlich für eigene Konfigurationen anlegen.
- **EK-1.5.2**: Alerts werden zuverlässig bei Erreichen der definierten Bedingungen ausgelöst.
- **EK-1.5.3**: Missbräuchliche oder systemgefährdende Konfigurationen werden verhindert.
- **EK-1.5.4**: Alert-Auslösungen werden nachvollziehbar protokolliert.

Relevante Security Requirements:

- **SR-2** – Autorisierung und Zugriffskontrolle *(Elevation of Privilege)*
- **SR-7** – Schutz vor Missbrauch *(Denial of Service)*
- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*

5.1.6 FA-1.6 Technische Analyse

Beschreibung:
Das System stellt technische Analysefunktionen und Indikatoren zur Bewertung von Finanzinstrumenten bereit.

Umfang:

- Berechnung technischer Indikatoren
- Darstellung der Ergebnisse in Charts
- Kombination mehrerer technischer Indikatoren

Erfüllungskriterien (EK):

- **EK-1.6.1**: Technische Indikatoren werden korrekt berechnet.
- **EK-1.6.2**: Ergebnisse technischer Analysen werden konsistent visualisiert.
- **EK-1.6.3**: Hohe Systemlast führt nicht zu Systemausfällen.

Relevante Security Requirements:

- **SR-5** – Sicherstellung der Datenintegrität *(Tampering)*
- **SR-10** – Sicherstellung der Verfügbarkeit *(Denial of Service)*

5.1.7 FA-1.7 Quantitative Analyse & Screening

Beschreibung:
Das System ermöglicht regelbasierte quantitative Analysen sowie das Screening von Finanzinstrumenten anhand definierter Kriterien.

Umfang:

- Definition regelbasierter Screening-Kriterien
- Durchführung quantitativer Analysen
- Vergleich und Auswertung von Analyseergebnissen

Erfüllungskriterien (EK):

- **EK-1.7.1**: Screening-Regeln werden korrekt interpretiert.
- **EK-1.7.2**: Analyseergebnisse sind konsistent reproduzierbar.
- **EK-1.7.3**: Rechenintensive Abfragen werden technisch begrenzt.

Relevante Security Requirements:

- **SR-5** – Sicherstellung der Datenintegrität *(Tampering)*
- **SR-7** – Schutz vor Missbrauch *(Denial of Service)*
- **SR-10** – Sicherstellung der Verfügbarkeit *(Denial of Service)*

5.1.8 FA-1.8 Makro- & Marktumfeld

Beschreibung:
Das System stellt makroökonomische Kennzahlen sowie Marktübersichten zur Kontextualisierung einzelner Analysen bereit.

Umfang:

- Darstellung makroökonomischer Indikatoren
- Bereitstellung von Marktüberblicken
- Zeitliche Vergleiche makroökonomischer und marktbezogener Daten

Erfüllungskriterien (EK):

- **EK-1.8.1**: Makroökonomische Daten werden ausschließlich aus definierten externen Quellen bezogen.
- **EK-1.8.2**: Daten werden konsistent und in definierten Intervallen aktualisiert.
- **EK-1.8.3**: Die Darstellung erfolgt ohne Offenlegung interner Systemdetails.

Relevante Security Requirements:

- **SR-6** – Absicherung externer Schnittstellen *(Tampering)*
- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*
- **SR-10** – Sicherstellung der Verfügbarkeit *(Denial of Service)*

5.2 EPIC 2: User Interface & Interaction Design

Ziel

Ziel dieses Epics ist die Gestaltung einer konsistenten, intuitiven und barrierearmen Benutzeroberfläche, die Nutzern eine effiziente und fehlerarme Interaktion mit den Kernfunktionen der Plattform ermöglicht. Der Fokus liegt auf einer klaren Informationsarchitektur, logisch aufgebauten Nutzungspfaden sowie einer performanten und responsiven Darstellung auf unterschiedlichen Endgeräten. Die Umsetzung berücksichtigt sicherheitsrelevante Darstellungsaspekte, um unbeabsichtigte Informationspreisgaben, Fehlbedienungen und Missverständnisse bei der Nutzung der Plattform zu vermeiden.

EPIC 2: User Interface & Interaction Design

Fokus:
Kernflows (FA-2.1),
Informationsarchitektur (FA-2.2),
Responsiveness (FA-2.3),
Charting (FA-2.4),
Benutzerfreundlichkeit & Performance (FA-2.5),
Barrierefreiheit & Lesbarkeit (FA-2.6),
Guided UX (FA-2.7),
Internationalisierung (FA-2.8)

5.2.1 FA-2.1 Kernflows

Beschreibung:
Das System stellt klar definierte und konsistente Kernnutzungspfade für die wichtigsten Funktionen der Plattform bereit.

Umfang:

- Navigation zwischen zentralen Kernfunktionen
- Einheitliche Seitenabfolgen innerhalb der Kernflows
- Reduktion unnötiger Interaktionsschritte

Erfüllungskriterien (EK):

- **EK-2.1.1**: Zentrale Funktionen sind über eine konsistente Abfolge von Interaktionsschritten erreichbar.
- **EK-2.1.2**: Kernflows verhalten sich über alle Nutzungskontexte hinweg gleichartig.
- **EK-2.1.3**: Fehlbedienungen werden durch klare und eindeutige UI-Rückmeldungen reduziert.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.2.2 FA-2.2 Informationsarchitektur

Beschreibung:
Das System strukturiert Inhalte logisch, nachvollziehbar und konsistent.

Umfang:

- Klare und abgegrenzte Inhaltsbereiche
- Eindeutige und konsistente Navigationsstruktur
- Vermeidung redundanter oder widersprüchlicher Darstellungen

Erfüllungskriterien (EK):

- **EK-2.2.1**: Inhalte sind thematisch eindeutig zugeordnet.
- **EK-2.2.2**: Navigationspfade sind konsistent und nachvollziehbar gestaltet.
- **EK-2.2.3**: Sensible Informationen werden nicht unkontrolliert dargestellt.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.2.3 FA-2.3 Responsiveness

Beschreibung:
Die Benutzeroberfläche passt sich unterschiedlichen Endgeräten und Bildschirmgrößen an.

Umfang:

- Darstellung auf Desktop-, Tablet- und mobilen Endgeräten
- Anpassung von Layouts und Interaktionselementen

Erfüllungskriterien (EK):

- **EK-2.3.1**: Alle Kernfunktionen sind auf unterschiedlichen Endgeräten nutzbar.
- **EK-2.3.2**: Inhalte bleiben vollständig sichtbar und bedienbar.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.2.4 FA-2.4 Charting

Beschreibung:
Das System stellt grafische Visualisierungen zur Analyse von Daten bereit.

Umfang:

- Interaktive Charts zur Datenanalyse
- Einheitliche Skalierung und konsistente Darstellung der Visualisierungen

Erfüllungskriterien (EK):

- **EK-2.4.1**: Charts stellen die zugrunde liegenden Daten korrekt dar.
- **EK-2.4.2**: Interaktionen mit Charts führen nicht zur Offenlegung zusätzlicher oder interner Informationen.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.2.5 FA-2.5 Benutzerfreundlichkeit & Performance

Beschreibung:
Die Benutzeroberfläche ermöglicht eine flüssige und effiziente Nutzung der Plattform.

Umfang:

- Schnelle Reaktionszeiten der Benutzeroberfläche
- Vermeidung unnötiger Lade- und Wartezeiten

Erfüllungskriterien (EK):

- **EK-2.5.1**: UI-Reaktionen erfolgen ohne wahrnehmbare Verzögerungen.
- **EK-2.5.2**: Performance-Probleme führen nicht zu inkonsistenter oder fehlerhafter Darstellung.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.2.6 FA-2.6 Barrierefreiheit & Lesbarkeit

Beschreibung:
Die Benutzeroberfläche ist barrierearm und gut lesbar gestaltet.

Umfang:

- Kontrastreiche Darstellung der Inhalte
- Skalierbare Schriftgrößen
- Verständliche und eindeutige Beschriftungen

Erfüllungskriterien (EK):

- **EK-2.6.1**: Inhalte bleiben auch bei vergrößerter Darstellung vollständig nutzbar.
- **EK-2.6.2**: Informationen sind klar, eindeutig und verständlich formuliert.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.2.7 FA-2.7 Guided UX

Beschreibung:
Das System unterstützt Nutzer durch kontextbezogene Hinweise und erklärende Informationen.

Umfang:

- Bereitstellung von Tooltips
- Kontextuelle Hinweise zur Nutzung der Plattform
- Schrittweise Unterstützung bei komplexeren Interaktionen

Erfüllungskriterien (EK):

- **EK-2.7.1**: Hinweise unterstützen die Nutzung ohne Informationsüberladung.
- **EK-2.7.2**: Hinweise enthalten keine internen oder sensiblen Systemdetails.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.2.8 FA-2.8 Internationalisierung

Beschreibung:
Die Benutzeroberfläche unterstützt mehrere Sprachen und regionale Einstellungen.

Umfang:

- Umschaltung zwischen unterstützten Sprachen
- Anzeige lokalisierter Texte und Inhalte

Erfüllungskriterien (EK):

- **EK-2.8.1**: Inhalte werden konsistent und korrekt übersetzt.
- **EK-2.8.2**: Ein Sprachwechsel beeinflusst weder Zugriffsrechte noch die Anzeige von Daten.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.3 EPIC 3: Information Presentation & Risk Communication

Ziel:

Ziel dieses Epics ist die kontrollierte, verständliche und kontextgerechte Darstellung von Informationen, Risiken und Systemzuständen gegenüber dem Nutzer. Dabei soll sichergestellt werden, dass fachliche Inhalte wie Marktdaten, Nachrichten und Analyseergebnisse korrekt interpretiert werden können, während gleichzeitig Fehlbedienungen, Fehlinformationen sowie unbeabsichtigte Informationspreisgaben vermieden werden. Die Umsetzung dieses Epics trägt wesentlich zur Transparenz, Nutzeraufklärung und zur sicheren Nutzung der Plattform bei.

EPIC 3: Information Presentation & Risk Communication

Fokus:

Darstellung von Marktdaten & Analysen (FA-3.1),
Nachrichten- & Sentimentdarstellung (FA-3.2),
Risikohinweise & Warnmeldungen (FA-3.3),
Fehlerzustände & Systemmeldungen (FA-3.4),
Bestätigungs- & Hinweisstufen (FA-3.5)

5.3.1 FA-3.1 Darstellung von Marktdaten & Analysen

Beschreibung:
Das System stellt Marktdaten und Analyseergebnisse verständlich, konsistent und kontextbezogen dar.

Umfang:

- Visualisierung von Analyseergebnissen
- Kontextualisierung von Kennzahlen
- Einheitliche Darstellungslogik

Erfüllungskriterien (EK):

- **EK-3.1.1**: Marktdaten und Analyseergebnisse werden konsistent dargestellt.
- **EK-3.1.2**: Die Darstellung ermöglicht eine eindeutige Interpretation der Daten.
- **EK-3.1.3**: Es werden keine internen Systemdetails offengelegt.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*
- **SR-5** – Sicherstellung der Datenintegrität *(Tampering)*

5.3.2 FA-3.2 Nachrichten- & Sentimentdarstellung

Beschreibung:
Das System präsentiert Nachrichten- und Sentimentinformationen klar getrennt von Analyseergebnissen und eindeutig als externe Inhalte gekennzeichnet.

Umfang:

- Trennung von Fakten, Analysen und Meinungen
- Kennzeichnung externer Inhalte
- Kontextbezogene Darstellung

Erfüllungskriterien (EK):

- **EK-3.2.1**: Externe Inhalte sind eindeutig als solche gekennzeichnet.
- **EK-3.2.2**: Nachrichten werden nicht mit systemeigenen Analysen vermischt.
- **EK-3.2.3**: Die Darstellung verhindert Fehlinterpretationen.

Relevante Security Requirements:

- **SR-6** – Absicherung externer Schnittstellen *(Tampering)*
- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.3.3 FA-3.3 Risikohinweise & Warnmeldungen

Beschreibung:
Das System informiert Nutzer über Risiken, Unsicherheiten und Grenzen der dargestellten Informationen.

Umfang:

- Risikohinweise bei Analysen
- Warnungen bei unvollständigen oder unsicheren Daten
- Hinweise auf externe Abhängigkeiten

Erfüllungskriterien (EK):

- **EK-3.3.1**: Risikohinweise sind klar und verständlich formuliert.
- **EK-3.3.2**: Hinweise erscheinen kontextbezogen bei relevanten Aktionen.
- **EK-3.3.3**: Hinweise enthalten keine technischen oder internen Details.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*
- **SR-10** – Sicherstellung der Verfügbarkeit *(Denial of Service)*

5.3.4 FA-3.4 Fehlerzustände & Systemmeldungen

Beschreibung:
Das System stellt Fehlerzustände und Systemmeldungen kontrolliert und nutzerverständlich dar.

Umfang:

- Einheitliche Fehlermeldungen
- Trennung von Nutzer- und Systeminformationen
- Kontextbezogene Anzeige von Systemmeldungen

Erfüllungskriterien (EK):

- **EK-3.4.1**: Fehlermeldungen sind verständlich und handlungsleitend formuliert.
- **EK-3.4.2**: Interne Systemdetails werden nicht offengelegt.
- **EK-3.4.3**: Fehler werden konsistent behandelt und dargestellt.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*
- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*

5.3.5 FA-3.5 Bestätigungs- & Hinweisstufen

Beschreibung:
Das System verwendet abgestufte Bestätigungs- und Hinweismechanismen für potenziell kritische Nutzeraktionen.

Umfang:

- Bestätigungen vor kritischen Aktionen
- Unterschiedliche Hinweisstufen
- Konsistente Interaktionslogik

Erfüllungskriterien (EK):

- **EK-3.5.1**: Kritische Aktionen erfordern eine explizite Bestätigung.
- **EK-3.5.2**: Hinweisstufen sind konsistent definiert.
- **EK-3.5.3**: Bestätigungsmechanismen verhindern unbeabsichtigte Aktionen.

Relevante Security Requirements:

- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*
- **SR-2** – Autorisierung und Zugriffskontrolle *(Elevation of Privilege)*

5.4 EPIC 4: Trust, Transparency & UX-Security

Ziel:
Ziel dieses Epics ist es, das Vertrauen der Nutzer in die Plattform durch transparente, nachvollziehbare und konsistente sicherheitsbezogene Rückmeldungen zu stärken. Dabei werden sicherheitsrelevante Aspekte nicht nur auf technischer Ebene umgesetzt (siehe EPIC 5), sondern gezielt aus Nutzersicht sichtbar und verständlich gemacht. Durch klare Rückmeldungen, nachvollziehbare Bestätigungen, Einsichtsmöglichkeiten und transparente Feature-Zugriffe soll die sichere Nutzung der Plattform unterstützt und das Sicherheitsbewusstsein der Nutzer gefördert werden.

EPIC 3: Information Presentation & Risk Communication

Fokus:
Sicherheit & Vertrauen (FA-4.1),
Transparenz sicherheitsrelevanter Aktionen (FA-4.2),
Auditierbarkeit aus Nutzersicht (FA-4.3),
Feature- & Zugriffstransparenz (FA-4.4),
Personalisierung & Sichtbarkeit von Sicherheitsfunktionen (FA-4.5)

5.4.1 FA-4.1 Sicherheit & Vertrauen

Beschreibung:
Das System vermittelt Nutzern ein konsistentes Sicherheits- und Vertrauensgefühl durch klare, verständliche und erwartungskonforme Rückmeldungen.

Umfang:

- Sichtbare Sicherheitsindikatoren
- Konsistente Rückmeldungen bei sicherheitsrelevanten Aktionen
- Vermeidung widersprüchlicher UI-Signale

Erfüllungskriterien (EK):

- **EK-4.1.1**: Sicherheitsrelevante Aktionen sind für Nutzer nachvollziehbar.
- **EK-4.1.2**: Rückmeldungen sind konsistent und eindeutig formuliert.
- **EK-4.1.3**: Die Darstellung erzeugt keine falschen Sicherheitsannahmen.

Relevante Security Requirements:

- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*
- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.4.2 FA-4.2 Transparenz sicherheitsrelevanter Aktionen

Beschreibung:
Das System macht sicherheitsrelevante Aktionen für Nutzer transparent, ohne technische Details offenzulegen.

Umfang:

- Hinweise bei sicherheitsrelevanten Änderungen
- Rückmeldungen bei kritischen Aktionen
- Zeitnahe Benachrichtigungen

Erfüllungskriterien (EK):

- **EK-4.2.1**: Nutzer erhalten Rückmeldungen zu sicherheitsrelevanten Aktionen.
- **EK-4.2.2**: Rückmeldungen sind verständlich und nicht technisch formuliert.
- **EK-4.2.3**: Es werden keine internen Systeminformationen offengelegt.

Relevante Security Requirements:

- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*
- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.4.3 FA-4.3 Auditierbarkeit aus Nutzersicht

Beschreibung:
Das System ermöglicht Nutzern eine nachvollziehbare Einsicht in sicherheitsrelevante Aktivitäten im eigenen Nutzungskontext.

Umfang:

- Einsicht in sicherheitsrelevante Aktionen
- Zeitliche Einordnung von Ereignissen
- Beschränkung auf eigene Aktivitäten

Erfüllungskriterien (EK):

- **EK-4.3.1**: Nutzer können eigene sicherheitsrelevante Aktivitäten einsehen.
- **EK-4.3.2**: Ereignisse sind zeitlich eindeutig zugeordnet.
- **EK-4.3.3**: Nutzer erhalten keinen Zugriff auf fremde oder administrative Daten.

Relevante Security Requirements:

- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*
- **SR-12** – Schutz von Protokolldaten *(Tampering)*

5.4.4 FA-4.4 Feature- & Zugriffstransparenz

Beschreibung:
Das System stellt transparent dar, welche Funktionen für den jeweiligen Nutzer verfügbar sind und warum bestimmte Funktionen eingeschränkt sind.

Umfang:

- Sichtbarkeit freigeschalteter Funktionen
- Erläuterung eingeschränkter Features
- Konsistente Darstellung von Berechtigungen

Erfüllungskriterien (EK):

- **EK-4.4.1**: Nutzer erkennen, welche Funktionen ihnen zur Verfügung stehen.
- **EK-4.4.2**: Einschränkungen werden verständlich begründet.
- **EK-4.4.3**: Die Darstellung verhindert Fehlannahmen über Berechtigungen.

Relevante Security Requirements:

- **SR-2** – Autorisierung und Zugriffskontrolle *(Elevation of Privilege)*
- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*

5.4.5 FA-4.5 Personalisierung & Sichtbarkeit von Sicherheitsfunktionen

Beschreibung:
Das System ermöglicht eine personalisierte Darstellung sicherheitsrelevanter Informationen, ohne Sicherheitsmechanismen zu schwächen.

Umfang:

- Anpassbare Anzeige sicherheitsrelevanter Hinweise
- Personalisierte Benachrichtigungen
- Konsistente Sicherheitsdarstellung

Erfüllungskriterien (EK):

- **EK-4.5.1**: Personalisierung beeinflusst keine Sicherheitslogik.
- **EK-4.5.2**: Sicherheitsinformationen bleiben stets sichtbar.
- **EK-4.5.3**: Personalisierte Darstellungen führen nicht zu Informationsverlust.

Relevante Security Requirements:

- **SR-9** – Schutz vor ungewollter Informationspreisgabe *(Information Disclosure)*
- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*

5.5 EPIC 5: Platform Security & Access Control

Ziel:
Ziel dieses Epics ist die Umsetzung zentraler technischer Sicherheitsmechanismen zur Absicherung der Plattform gegen unbefugten Zugriff, Missbrauch, Manipulation und Ausfälle. Dabei werden Authentifizierung, Autorisierung, Schnittstellensicherheit sowie Schutzmaßnahmen zur Wahrung von Vertraulichkeit, Integrität und Verfügbarkeit systematisch umgesetzt. EPIC 5 bildet die technische Grundlage zur Erfüllung der in der Analyse definierten Security Requirements und stellt sicher, dass Sicherheitskontrollen nicht isoliert, sondern integraler Bestandteil der Systemarchitektur sind.

EPIC 5: EPIC 5: Platform Security & Access Control

Fokus:
Authentifizierung (FA-5.1),
Autorisierung & Rollenmodelle (FA-5.2),
Sitzungs- & Zugriffssicherheit (FA-5.3),
Schnittstellensicherheit (FA-5.4),
Missbrauchs- & Angriffsschutz (FA-5.5),
Protokollierung & Sicherheitsüberwachung (FA-5.6)

5.5.1 FA-5.1 Authentifizierung

Beschreibung:
Das System erzwingt eine eindeutige Authentifizierung aller Nutzer vor dem Zugriff auf personalisierte oder sicherheitsrelevante Funktionen.

Umfang:

- Anmeldung von Nutzern
- Verifikation von Identitäten
- Absicherung des Authentifizierungsprozesses

Erfüllungskriterien (EK):

- **EK-5.1.1**: Der Zugriff auf personalisierte Funktionen ist ausschließlich nach erfolgreicher Authentifizierung möglich.
- **EK-5.1.2**: Fehlgeschlagene Authentifizierungsversuche werden erkannt und begrenzt.
- **EK-5.1.3**: Authentifizierungsereignisse werden nachvollziehbar protokolliert.

Relevante Security Requirements:

- **SR-1** – Authentisierung *(Spoofing)*
- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*

5.5.2 FA-5.2 Autorisierung & Rollenmodelle

Beschreibung:
Das System stellt sicher, dass Nutzer ausschließlich auf die für sie freigegebenen Funktionen und Daten zugreifen können.

Umfang:

- Rollenbasierte Zugriffskontrolle
- Funktions- und datenbezogene Berechtigungen
- Zentrale Durchsetzung der Autorisierungslogik

Erfüllungskriterien (EK):

- **EK-5.2.1**: Zugriffe werden serverseitig anhand definierter Rollen geprüft.
- **EK-5.2.2**: Unautorisierte Zugriffsversuche werden zuverlässig verhindert.
- **EK-5.2.3**: Änderungen an Berechtigungen sind nachvollziehbar.

Relevante Security Requirements:

- **SR-2** – Autorisierung und Zugriffskontrolle *(Elevation of Privilege)*
- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*

5.5.3 FA-5.3 Sitzungs- & Zugriffssicherheit

Beschreibung:
Das System schützt aktive Sitzungen und Zugriffskontexte vor Übernahme, Manipulation oder Missbrauch.

Umfang:

- Verwaltung von Sitzungen
- Zeitliche Begrenzung von Zugriffen
- Sichere Beendigung von Sitzungen

Erfüllungskriterien (EK):

- **EK-5.3.1**: Sitzungen sind zeitlich begrenzt und eindeutig zugeordnet.
- **EK-5.3.2**: Sitzungen können kontrolliert beendet werden.
- **EK-5.3.3**: Ungewöhnliche Zugriffsmuster werden erkannt.

Relevante Security Requirements:

- **SR-1** – Authentisierung *(Spoofing)*
- **SR-9** – Verfügbarkeitsschutz *(Denial of Service)*

5.5.4 FA-5.4 Schnittstellensicherheit

Beschreibung:
Das System schützt interne und externe Schnittstellen vor unautorisiertem Zugriff und Manipulation.

Umfang:

- Absicherung aller APIs
- Validierung eingehender Anfragen
- Kontrolle zulässiger Operationen

Erfüllungskriterien (EK):

- **EK-5.4.1**: Schnittstellen sind ausschließlich über definierte Zugriffsmechanismen nutzbar.
- **EK-5.4.2**: Eingehende Anfragen werden vor der Verarbeitung validiert.
- **EK-5.4.3**: Missbräuchliche Schnittstellennutzung wird begrenzt.

Relevante Security Requirements:

- **SR-7** – Schnittstellensicherheit *(Tampering, Denial of Service)*
- **SR-9** – Verfügbarkeitsschutz *(Denial of Service)*

5.5.5 FA-5.5 Missbrauchs- & Angriffsschutz

Beschreibung:
Das System implementiert Schutzmechanismen zur Erkennung und Begrenzung missbräuchlicher oder angreifender Nutzung.

Umfang:

- Schutz vor automatisierten Angriffen
- Begrenzung ressourcenintensiver Aktionen
- Erkennung auffälliger Nutzungsmuster

Erfüllungskriterien (EK):

- **EK-5.5.1**: Automatisierte oder auffällige Zugriffe werden begrenzt.
- **EK-5.5.2**: Schutzmechanismen beeinträchtigen legitime Nutzung nicht unverhältnismäßig.
- **EK-5.5.3**: Sicherheitsrelevante Ereignisse werden protokolliert.

Relevante Security Requirements:

- **SR-9** – Verfügbarkeitsschutz *(Denial of Service)*
- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*

5.5.6 FA-5.6 Protokollierung & Sicherheitsüberwachung

Beschreibung:
Das System erfasst sicherheitsrelevante Ereignisse zentral und stellt diese für Analyse- und Nachvollziehbarkeitszwecke bereit.

Umfang:

- Erfassung sicherheitsrelevanter Ereignisse
- Schutz von Protokolldaten
- Unterstützung von Analyse und Monitoring

Erfüllungskriterien (EK):

- **EK-5.6.1**: Sicherheitsrelevante Ereignisse werden vollständig protokolliert.
- **EK-5.6.2**: Protokolldaten sind gegen Manipulation geschützt.
- **EK-5.6.3**: Protokolle unterstützen die Nachvollziehbarkeit von Vorfällen.

Relevante Security Requirements:

- **SR-11** – Protokollierung sicherheitsrelevanter Aktionen *(Repudiation)*
- **SR-12** – Schutz von Protokolldaten *(Tampering)*

6 Einordnung des Projekts in den Secure Software Development Lifecycle (SSDLC)

Das vorliegende Projekt wird vollständig entlang des Secure Software Development Lifecycle (SSDLC) umgesetzt. Der SSDLC dient dabei als verbindlicher Rahmen für alle Phasen der Softwareentwicklung und stellt sicher, dass Sicherheitsaspekte systematisch, durchgängig und nachvollziehbar berücksichtigt werden.

secbydesign! warum nehmen wir secure SDLC?

Bereits in der Planungs- und Anforderungsphase werden sicherheitsrelevante Zielsetzungen definiert und in Form konkreter Security Requirements festgehalten. Diese Anforderungen bilden die verbindliche Grundlage für alle nachfolgenden Entwicklungsphasen. In der Analyse- und Designphase erfolgt eine strukturierte Identifikation und Bewertung potenzieller Bedrohungen mittels eines etablierten Threat-Modeling-Ansatzes. Die identifizierten Bedrohungen werden den definierten Security Requirements zugeordnet, sodass eine durchgängige Rückverfolgbarkeit zwischen Bedrohungen, Anforderungen und geplanten Sicherheitsmaßnahmen gewährleistet ist.

Auf Basis der Ergebnisse aus der Anforderungsanalyse und dem Threat-Modeling werden sicherheitsrelevante Architektur- und Designentscheidungen getroffen. Diese Entscheidungen dienen der gezielten Umsetzung der definierten Sicherheitsanforderungen und adressieren insbesondere die Schutzziele Vertraulichkeit, Integrität und Verfügbarkeit. Sicherheitskontrollen werden dabei nicht isoliert betrachtet, sondern als integraler Bestandteil des Gesamtsystems entworfen.

In der Implementierungsphase werden die entworfenen Sicherheitsmaßnahmen gemäß der definierten Designvorgaben umgesetzt. Ergänzend hierzu ist die Verifikationsphase fester Bestandteil des SSDLC, in der die Einhaltung der Sicherheitsanforderungen sowie die Wirksamkeit der implementierten Sicherheitskontrollen überprüft werden. Hierzu werden geeignete sicherheitsrelevante Tests und Prüfmechanismen vorgesehen.

Auch die Phasen Release und Betrieb sind explizit Bestandteil des SSDLC. Sicherheitsaspekte wie Protokollierung, Monitoring, der Umgang mit Sicherheitsvorfällen sowie

release und betieb klingt weird, vllt anführungs-

das Management von Schwachstellen werden konzeptionell berücksichtigt und in den Entwicklungsprozess integriert. Dadurch wird sichergestellt, dass Sicherheitsanforderungen nicht nur während der Entwicklung, sondern über den gesamten Lebenszyklus der Software hinweg eingehalten werden.

Zusammenfassend bildet der Secure Software Development Lifecycle den verbindlichen methodischen Rahmen des Projekts. Durch die konsequente Anwendung des SSDLC in allen Phasen der Softwareentwicklung wird eine ganzheitliche und nachhaltige Berücksichtigung von Sicherheitsaspekten gewährleistet.

nicht maintenance oder?

7 Analyse

7.1 Security Requirements Engineering:

Zielsystem:
Eine digitale Plattform zur Marktanalyse und Entscheidungsunterstützung für Privatanleger, die verschiedene Datenquellen integriert, Informationen aufbereitet und nutzerfreundlich visualisiert.

Primäre Assets:

- Nutzerkonten und Identitäten
- Finanz- und Profildaten der Nutzer
- Analyseergebnisse und Marktdaten
- Systemverfügbarkeit und -integrität

Stakeholder (relevant für Sicherheit):

- Endnutzer (Privatanleger)
- Plattformbetreiber
- Externe Datenanbieter (APIs)
- Potenzielle Angreifer (z. B. Datenabgriff, Manipulation, Missbrauch)

7.1.1 Security Goals (übergeordnete Sicherheitsziele)

Sicherheitsziel	Beschreibung
SG-1 Vertraulichkeit	Unbefugte dürfen keinen Zugriff auf personenbezogene Daten, Nutzungsprofile oder Analyseergebnisse erhalten.
SG-2 Integrität	Daten, Analysen und Visualisierungen dürfen nicht unbemerkt manipuliert werden.
SG-3 Authentizität & Autorisierung	Nur berechtigte Nutzer dürfen auf Funktionen und Daten zugreifen.
SG-4 Verfügbarkeit	Die Plattform muss auch bei hoher Last oder gezielten Angriffen verfügbar bleiben.
SG-5 Nachvollziehbarkeit & Transparenz	Sicherheitsrelevante Aktionen müssen nachvollziehbar protokolliert werden.

¥

Tabelle II: Übersicht der Sicherheitsziele

7.1.2 Bedrohungsanalyse (Threats)

Bedrohung	Beschreibung
T-1 Unbefugter Zugriff auf Nutzerkonten	Angreifer verschaffen sich Zugriff auf Nutzerkonten, beispielsweise durch schwache Authentisierungsmechanismen oder kompromittierte Zugangsdaten.
T-2 Manipulation von Analyse- oder Marktdaten	Analyseergebnisse oder zugrunde liegende Marktdaten werden gezielt verändert, um falsche Schlussfolgerungen oder Entscheidungen zu provozieren.
T-3 Missbrauch der Plattform zur Fehlinformation oder Marktbeeinflussung	Die Plattform wird genutzt, um gezielt irreführende Informationen zu verbreiten oder Marktmechanismen zu beeinflussen.
T-4 Datenabfluss über unsichere Schnittstellen (APIs)	Vertrauliche Daten werden über unzureichend abgesicherte Programmierschnittstellen abgegriffen oder unbefugt weitergegeben.
T-5 Ausfall der Plattform durch Überlastung oder gezielte Angriffe (DoS)	Die Verfügbarkeit der Plattform wird durch hohe Last oder gezielte Denial-of-Service-Angriffe eingeschränkt oder vollständig unterbrochen.

Tabelle IV: Übersicht der identifizierten Bedrohungen

7.1.3 Abgeleitete Security Requirements (Kernstück)

Kategorie	Requirement	Beschreibung
Authentisierung & Autorisierung	SR-1 Authentisierung	Das System muss eine eindeutige Authentisierung aller Nutzer vor dem Zugriff auf personalisierte Funktionen erzwingen.
Authentisierung & Autorisierung	SR-2 Autorisierung	Das System muss rollenbasierte Zugriffskontrollen implementieren, sodass Nutzer ausschließlich auf für sie freigegebene Funktionen und Daten zugreifen können.
Schutz personenbezogener Daten	SR-3 Schutz personenbezogener Daten	Alle personenbezogenen Nutzerdaten müssen während der Übertragung und der Speicherung angemessen geschützt werden.
Schutz personenbezogener Daten	SR-4 Zweckbindung	Das System darf personenbezogene Daten ausschließlich für den vorgesehenen und definierten Zweck verarbeiten.
Datenintegrität & Analysevertrauen	SR-5 Datenintegrität	Das System muss sicherstellen, dass Analyseergebnisse nicht unbemerkt verändert werden können.
Datenintegrität & Analysevertrauen	SR-6 Externe Datenquellen	Daten aus externen Quellen müssen vor ihrer Weiterverarbeitung auf Integrität und Plausibilität geprüft werden.
Schnittstellen & externe Abhängigkeiten	SR-7 Schnittstellensicherheit	Externe Schnittstellen müssen gegen unautorisierte Zugriffe abgesichert werden.

Kategorie	Requirement	Beschreibung
Schnittstellen & externe Abhängigkeiten	SR-8 Fehler- und Manipulationserkennung	Das System muss fehlerhafte oder manipulierte externe Daten erkennen und entsprechend behandeln.
Verfügbarkeit & Robustheit	SR-9 Verfügbarkeitsschutz	Das System soll Mechanismen zur Begrenzung von Missbrauch und Überlastung implementieren.
Verfügbarkeit & Robustheit	SR-10 Fehlertoleranz	Sicherheitskritische Funktionen dürfen auch bei Teilausfällen nicht in einen unsicheren Zustand übergehen.
Logging & Nachvollziehbarkeit	SR-11 Logging	Sicherheitsrelevante Ereignisse müssen nachvollziehbar protokolliert werden.
Logging & Nachvollziehbarkeit	SR-12 Schutz von Protokolldaten	Protokolldaten dürfen nicht durch normale Nutzer manipuliert oder gelöscht werden können.

Tabelle V: Abgeleitete Security Requirements

7.2 Threat Modeling:

7.3 Abgrenzung & Annahmen

7.3.1 Systemgrenzen

Das betrachtete System umfasst folgende Komponenten:

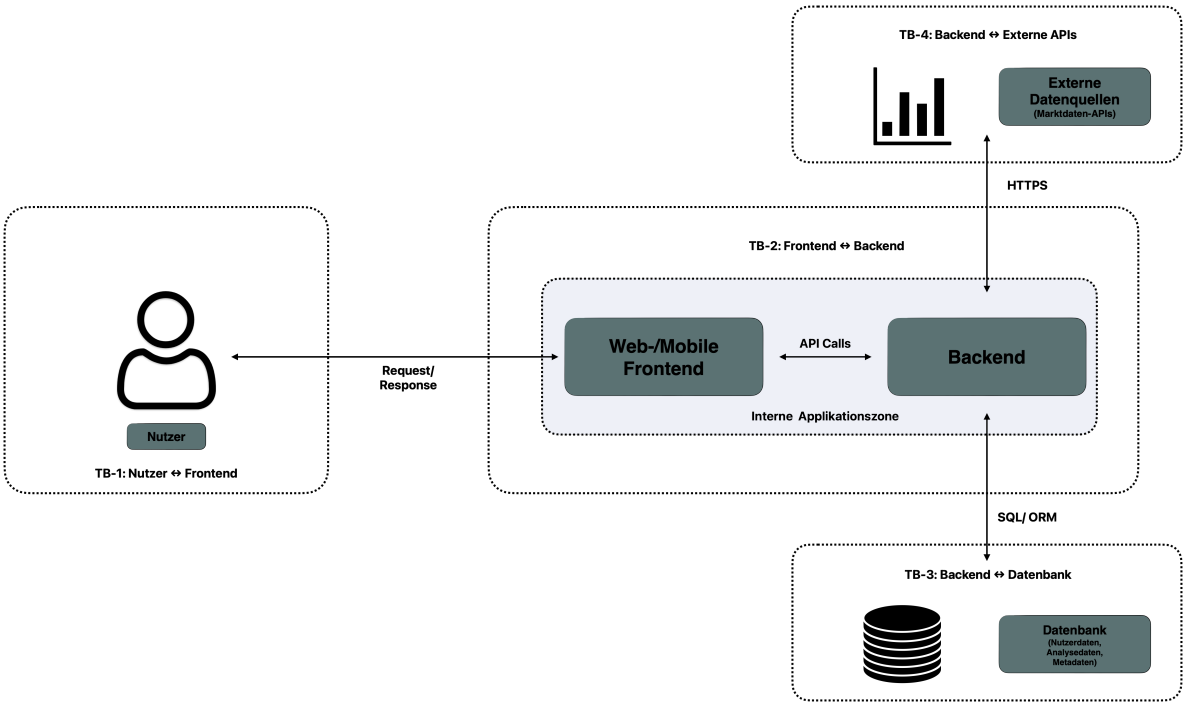
- Web-/Mobile-Frontend
- Backend (Business-Logik, Analyse)
- Datenbank (Nutzer-, Analyse- und Metadaten)
- Externe Datenquellen (Marktdaten-APIs)

7.3.2 Trust Boundaries

Innerhalb des Systems existieren mehrere Vertrauensgrenzen (Trust Boundaries), an denen Daten zwischen Komponenten mit unterschiedlichem Vertrauensniveau ausgetauscht werden:

- TB-1: Nutzer ↔ Frontend
- TB-2: Frontend ↔ Backend
- TB-3: Backend ↔ Datenbank
- TB-4: Backend ↔ Externe APIs

Diese Trust Boundaries sind sicherheitsrelevant, da jeder Übergang einen potenziellen Angriffspunkt darstellt und daher besondere Schutzmaßnahmen erfordert.



7.3.3 Angreiferprofile

A-1 Externer Angreifer Kein legitimer Zugriff auf das System.
Ziel: Datendiebstahl, Manipulation von Systemen oder Herbeiführung eines Systemausfalls.

A-2 Authentifizierter, aber böswilliger Nutzer Verfügt über einen legitimen Benutzeraccount.
Ziel: Privilegienausweitung sowie unautorisierter Zugriff auf sensible Daten.

A-3 Externer Dienst / kompromittierte API Externe Datenquelle liefert manipulierte oder fehlerhafte Daten.
Ziel: Verbreitung von Fehlinformationen und Vertrauensverlust in das System.

7.3.4 STRIDE-Analyse

S – Spoofing (Identitätsvortäuschung) TM-S1: Angreifer gibt sich als legitimer Nutzer aus (z. B. durch kompromittierte Zugangsdaten).

- **Betroffene Assets: Nutzerkonten und personalisierte Analysen**
- **Auswirkung:** Unbefugter Zugriff auf sensible Daten.

T – Tampering (Manipulation) TM-T1: Manipulation von Analyseergebnissen oder Marktdaten während der Übertragung.
TM-T2: Veränderung gespeicherter Daten durch Ausnutzung unzureichender Zugriffskontrollen.

- **Auswirkung:** Fehlentscheidungen der Nutzer, Vertrauensverlust.

R – Repudiation (Abstreitbarkeit) TM-R1: Nutzer oder Angreifer können sicherheitsrelevante Aktionen abstreiten, da keine belastbaren Protokollierungsmechanismen existieren.

- **Auswirkung:** Fehlende Nachvollziehbarkeit sowie Compliance-Risiken.

I – Information Disclosure (Informationspreisgabe) TM-I1: Abfluss personenbezogener Daten über unsichere Schnittstellen.
TM-I2: Unbeabsichtigte Offenlegung sensibler Analyse- oder Nutzungsdaten.

- **Auswirkung:** Datenschutzverletzungen und regulatorische Konsequenzen.

D – Denial of Service (Dienstverweigerung) TM-D1: Überlastung des Systems durch gezielte oder automatisierte Anfragen.
TM-D2: Ausfall externer Datenquellen führt zu einem teilweisen oder vollständigen Systemstillstand.

- **Auswirkung:** Nichtverfügbarkeit der Plattform.

E – Elevation of Privilege (Rechteausweitung) TM-E1: Ein regulärer Nutzer erlangt administrative oder erweiterte Analysefunktionen.

- **Auswirkung:** Manipulation von Systemfunktionen oder sensiblen Daten.

7.3.5 Konsolidierte Threat-Liste

ID	Kategorie	Bedrohung	Beschreibung	Typischer Angriffsvektor	Betroffenes Ziel
TM-S1	Spoofing	Identitätsvortäuschung	Ein Angreifer gibt sich als legitimer Nutzer oder Systemkomponente aus, um unautorisierten Zugriff auf personalisierte Funktionen oder sensible Daten zu erhalten.	Gestohlene Zugangsdaten, schwache Authentisierung, Session-Hijacking	SG-1, SG-3
TM-T1	Tampering	Manipulation externer Daten	Von externen Datenquellen bezogene Markt- oder Analysedaten werden während der Übertragung oder durch kompromittierte APIs verändert.	Man-in-the-Middle, kompromittierte Drittanbieter-APIs	SG-2
TM-T2	Tampering	Manipulation interner Daten	Interne Daten wie Analyseergebnisse, Nutzerprofile oder Konfigurationswerte werden unbefugt verändert.	Unzureichende Zugriffskontrollen, Injection-Angriffe	SG-2
TM-R1	Repudiation	Fehlende Nachvollziehbarkeit	Sicherheitsrelevante Aktionen können nicht eindeutig einem Akteur zugeordnet oder im Nachhinein rekonstruiert werden.	Fehlende oder manipulierbare Logs	SG-5
TM-I1	Information Disclosure	Datenabfluss über APIs	Sensible Nutzerdaten oder interne Informationen werden über unsichere oder falsch konfigurierte Schnittstellen offengelegt.	Unsichere API-Endpunkte, Fehlkonfigurationen	SG-1
TM-I2	Information Disclosure	Offenlegung von Analyseergebnissen	Analyseergebnisse oder personalisierte Auswertungen werden unbefugten Dritten zugänglich gemacht.	Fehlende Zugriffsbeschränkungen, Caching-Probleme	SG-1
TM-D1	Denial of Service	Überlastung des Systems	Das System wird durch eine große Anzahl von Anfragen oder gezielte Angriffe in seiner Funktion beeinträchtigt oder vollständig lahmgelegt.	Traffic-Flooding, automatisierte Requests	SG-4
TM-D2	Denial of Service	Abhängigkeit externer Dienste	Der Ausfall externer Datenquellen oder Services führt zu eingeschränkter oder vollständiger Nichtverfügbarkeit der Plattform.	API-Ausfälle, Netzwerkprobleme	SG-4
TM-E1	Elevation of Privilege	Rechteausweitung	Ein Nutzer erlangt höhere Berechtigungen als vorgesehen und erhält Zugriff auf administrative oder sicherheitskritische Funktionen.	Fehlende Autorisierungsprüfungen, Logikfehler	SG-3

Tabelle VI: STRIDE-Bedrohungen und Zuordnung zu Sicherheitszielen

ID	Bedrohung	EW	AW	Risiko	Begründung
TM-S1	Identitätsvortäuschung	3	3	9 (hoch)	Zugangsdaten sind ein häufiges Angriffsziel; bei erfolgreicher Kontoübernahme entstehen unbefugter Zugriff auf personenbezogene Daten sowie Missbrauch personalisierter Funktionen.
TM-T1	Manipulation externer Daten	2	3	6 (mittel)	Externe Datenquellen stellen eine Trust Boundary dar; manipulierte Marktdaten führen unmittelbar zu verfälschten Analysen und potenziell falschen Entscheidungen.
TM-T2	Manipulation interner Daten	2	3	6 (mittel)	Bei unzureichenden Zugriffskontrollen oder fehlender Validierung können interne Daten unbefugt verändert werden; betroffen sind Kernfunktionen, Datenintegrität und das Vertrauen in die Plattform.
TM-R1	Fehlende Nachvollziehbarkeit	2	2	4 (mittel)	Ohne vollständige und manipulationssichere Protokollierung sind Aktionen nicht belastbar nachvollziehbar; dies erschwert Forensik und erhöht Compliance-Risiken.
TM-I1	Datenabfluss über APIs	2	3	6 (mittel)	APIs sind eine typische Angriffsfläche; unzureichend abgesicherte Endpunkte können zur Offenlegung personenbezogener Daten führen und regulatorische Konsequenzen nach sich ziehen.
TM-I2	Offenlegung von Analyseergebnissen	2	2	4 (mittel)	Fehlkonfigurationen oder unzureichende Zugriffsbeschränkungen können personalisierte Auswertungen offenlegen; der Schaden ist häufig geringer als beim Abfluss personenbezogener Daten.
TM-D1	Überlastung des Systems	2	2	4 (mittel)	Automatisierte Anfragen und Traffic-Spitzen sind realistisch; dies kann die Verfügbarkeit temporär einschränken und die Nutzbarkeit der Plattform beeinträchtigen.
TM-D2	Abhängigkeit externer Dienste	3	2	6 (mittel)	Ausfälle externer APIs sind plausibel; zentrale Funktionen hängen von Marktdaten ab, die Auswirkungen können jedoch durch Degradations- und Fallback-Strategien begrenzt werden.
TM-E1	Rechteausweitung	2	3	6 (mittel)	Fehlerhafte Autorisierungsprüfungen oder Logikfehler ermöglichen Privilegieneskalation; dadurch kann Zugriff auf administrative oder sicherheitskritische Funktionen entstehen.

Tabelle VIII: Risikobewertung der identifizierten Bedrohungen (EW: Eintrittswahrscheinlichkeit, AW: Auswirkung; Risiko = EW $\times$ AW)

7.3.6 Traceability zwischen Bedrohungen, Security Requirements und Sicherheitszielen

Die identifizierten Bedrohungen werden den abgeleiteten Security Requirements sowie den übergeordneten Sicherheitszielen eindeutig zugeordnet. Ziel dieser Traceability ist es, die Nachvollziehbarkeit der Sicherheitsanforderungen und deren Motivation durch konkrete Bedrohungsszenarien sicherzustellen.

Die Bedrohung *TM-S1 (Identitätsvortäuschung)* adressiert primär Anforderungen zur Authentisierung und Autorisierung (SR-1, SR-2) sowie zum Schutz personenbezogener Daten (SR-3) und unterstützt damit die Sicherheitsziele Vertraulichkeit und Authentizität (SG-1, SG-3).

Manipulationen externer und interner Daten (*TM-T1*, *TM-T2*) werden durch Anforderungen zur Datenintegrität und zur Validierung externer Datenquellen (SR-5, SR-6, SR-8) adressiert und stehen im direkten Zusammenhang mit dem Sicherheitsziel Integrität (SG-2).

Die Bedrohung der fehlenden Nachvollziehbarkeit (*TM-R1*) wird durch Logging- und Protokollschutzanforderungen (SR-11, SR-12) mitigiert und unterstützt das Sicherheitsziel der Nachvollziehbarkeit und Transparenz (SG-5).

Informationspreisgaben über Schnittstellen oder unbefugte Offenlegung von Analyseergebnissen (*TM-I1*, *TM-I2*) werden durch Anforderungen zur Schnittstellensicherheit, Zugriffskontrolle und zum Schutz personenbezogener Daten (SR-2, SR-3, SR-7) adressiert und zielen auf die Wahrung der Vertraulichkeit (SG-1).

Verfügbarkeitsbedrohungen durch Überlastung oder Abhängigkeiten externer Dienste (*TM-D1*, *TM-D2*) werden durch Anforderungen zur Verfügbarkeitssicherung und Fehlertoleranz (SR-9, SR-10) adressiert und unterstützen das Sicherheitsziel der Verfügbarkeit (SG-4).

Die Bedrohung der Rechteausweitung (*TM-E1*) wird durch strikte Authentisierungs- und Autorisierungsmechanismen (SR-1, SR-2) sowie unterstützende Protokollierungsmaßnahmen (SR-11) mitigiert und trägt zur Erreichung der Sicherheitsziele Authentizität und Integrität (SG-3, SG-2) bei.

Kategorie	**Security Requirement**	**Abgeleitete Security Controls**
Authentisierung & Autorisierung	SR-1 Authentisierung	Einsatz von Authentisierungsmechanismen, Schutz vor Brute-Force-Angriffen sowie sichere Sitzungsverwaltung zur eindeutigen Identifikation von Nutzern.
Authentisierung & Autorisierung	SR-2 Autorisierung	Implementierung rollenbasierter Zugriffskontrollen (RBAC) sowie konsequente Berechtigungsprüfungen auf Funktions- und Datenebene.
Schutz personenbezogener Daten	SR-3 Schutz personenbezogener Daten	Verschlüsselung personenbezogener Daten bei Übertragung und Speicherung sowie Einschränkung des Zugriffs auf sensible Informationen.
Schutz personenbezogener Daten	SR-4 Zweckbindung	Datenminimierung, klare Definition von Verarbeitungszwecken und Trennung unterschiedlicher Verarbeitungs- und Nutzungskontexte.
Datenintegrität & Analysevertrauen	SR-5 Datenintegrität	Integritätsprüfungen und Validierungsmechanismen zur Vermeidung unbemerkter Manipulationen von Analyseergebnissen.
Datenintegrität & Analysevertrauen	SR-6 Externe Datenquellen	Validierung und Plausibilitätsprüfung externer Daten sowie Absicherung der Kommunikationskanäle zu Drittanbietern.

Kategorie	**Security Requirement**	**Abgeleitete Security Controls**
Schnittstellen & externe Abhängigkeiten	SR-7 Schnittstellensicherheit	Authentifizierung und Autorisierung von Schnittstellenzugriffen sowie Einschränkung zulässiger API-Operationen.
Schnittstellen & externe Abhängigkeiten	SR-8 Fehler- und Manipulationserkennung	Erkennung fehlerhafter oder manipulierter Eingangsdaten und kontrollierte Behandlung solcher Fälle durch definierte Fallback- und Degradationsmechanismen.
Verfügbarkeit & Robustheit	SR-9 Verfügbarkeitsschutz	Mechanismen zur Begrenzung von Missbrauch und Überlastung, beispielsweise durch Last- und Zugriffskontrollen.
Verfügbarkeit & Robustheit	SR-10 Fehlertoleranz	Fail-Safe-Mechanismen und kontrollierter Betrieb bei Teilausfällen, ohne Verletzung zentraler Sicherheitsziele.
Logging & Nachvollziehbarkeit	SR-11 Logging	Zentrale und vollständige Protokollierung sicherheitsrelevanter Ereignisse zur Unterstützung von Analyse und Nachvollziehbarkeit.
Logging & Nachvollziehbarkeit	SR-12 Schutz von Protokolldaten	Zugriffsbeschränkung auf Protokolldaten sowie Schutz vor Manipulation und unbefugter Löschung.

Tabelle IX: Ableitung von Security Controls aus den Security Requirements

8 Design

8.1 SR-1 (Authentisierung)

SR-1 (Authentisierung) wird durch ein verbindliches Authentisierungskonzept umgesetzt, das den Zugriff auf personalisierte Funktionen ausschließlich nach erfolgreicher Identifikation erlaubt. Hierzu werden eine sichere Sitzungs- bzw. Tokenverwaltung, Schutzmaßnahmen gegen Brute-Force- und Credential-Stuffing-Angriffe sowie eine abgesicherte Kommunikation vorgesehen. Die Sitzungsverwaltung stellt sicher, dass Authentisierungszustände nicht durch unsichere Client-Speicherung oder Session Hijacking kompromittiert werden. Ergänzend werden sicherheitsrelevante Authentisierungsereignisse protokolliert, um Missbrauch erkennen und nachvollziehen zu können.

- Festlegung eines zentralen Authentisierungskonzepts
- Entscheidung: Zugriff nur nach erfolgreichem Login
- Definition sicherer Session- oder Token-Verwaltung
- Schutz vor automatisierten Login-Angriffen (Rate Limits, Sperren)
- Absicherung der Übertragung (TLS)
- Logging von Login-Events (Grundlage für Monitoring & Forensik)

8.2 SR-2 (Autorisierung)

SR-2 (Autorisierung) wird durch rollenbasierte Zugriffskontrollen (RBAC) umgesetzt, die serverseitig an allen sicherheitsrelevanten Funktions- und Datenzugriffen durchgesetzt werden. Zugriff wird ausschließlich gewährt, wenn die Rolle des Nutzers die angeforderte Operation erlaubt; andernfalls erfolgt eine kontrollierte Ablehnung. Die Autorisierungslogik wird zentral implementiert, um Inkonsistenzen und Umgehungsmöglichkeiten zu vermeiden. Autorisierungsverletzungen sowie administrative Aktionen werden als sicherheitsrelevante Ereignisse protokolliert.

- Entscheidung für RBAC als Autorisierungsmodell
- Serverseitige Durchsetzung (kein Client-Trust)
- Zentrale Autorisierungsprüfung (Middleware / Policy Layer)
- Vermeidung verteilter, fehleranfälliger Prüfungen
- Logging von fehlgeschlagenen und privilegierten Zugriffen
- Direkte Mitigation von Rechteausweitung (TM-E1)

8.3 SR-3 (Schutz personenbezogener Daten)

SR-3 (Schutz personenbezogener Daten) wird durch ein mehrstufiges Datenschutz- und Sicherheitskonzept umgesetzt, das den Zugriff, die Speicherung und die Übertragung sensibler Informationen absichert. Personenbezogene Daten werden ausschließlich über abgesicherte Kommunikationskanäle verarbeitet und sind nur für autorisierte Systemkomponenten zugänglich. Auf Datenbankebene werden geeignete Schutzmechanismen eingesetzt, um unbefugte Einsichtnahme oder Manipulation zu verhindern. Der Zugriff auf personenbezogene Daten erfolgt ausschließlich über die Backend-Logik, sodass eine direkte Exposition gegenüber dem Client ausgeschlossen ist.

- Entscheidung: personenbezogene Daten dürfen nie direkt vom Client angesprochen werden
- Absicherung der Datenübertragung (z. B. TLS)
- Einschränkung des Datenzugriffs auf autorisierte Backend-Komponenten
- Schutz der gespeicherten Daten (z. B. Verschlüsselung, Zugriffsbeschränkung)
- Technische Umsetzung der in der Analyse identifizierten Datenschutzanforderungen
- Direkte Mitigation von Informationsabfluss (TM-I1 / TM-I2)

8.4 SR-4 (Zweckbindung und Datenminimierung)

SR-4 (Zweckbindung und Datenminimierung) wird durch eine klare Trennung von fachlichen Funktionen und personenbezogenen Daten umgesetzt. Es werden ausschließlich solche personenbezogenen Informationen verarbeitet und gespeichert, die für die Nutzung der angebotenen Funktionen erforderlich sind. Analyse- und Marktdaten werden logisch von nutzerbezogenen Informationen getrennt, um eine unzulässige Zweckausweitung zu vermeiden. Die Verarbeitung personenbezogener Daten erfolgt ausschließlich im Rahmen der vorgesehenen Funktionalität und nicht für darüberhinausgehende Zwecke.

- Festlegung: nur funktional notwendige Daten werden gespeichert
- Trennung von Nutzerdaten und Analyse-/Marktdaten im Systemdesign
- Vermeidung von Mehrfachverwendung personenbezogener Daten
- Reduktion der Angriffsfläche durch geringere Datenhaltung
- Umsetzung der Datenschutzprinzipien Purpose Limitation und Data Minimization
- Absicherung gegen sekundären Missbrauch und unkontrollierte Datenaggregation

8.5 SR-5 (Datenintegrität)

SR-5 (Datenintegrität) wird durch technische und organisatorische Maßnahmen umgesetzt, die sicherstellen, dass verarbeitete und gespeicherte Daten nicht unbemerkt verändert werden können. Integritätsprüfungen werden insbesondere an sicherheitsrelevanten Übergängen innerhalb des Systems durchgeführt, um Manipulationen frühzeitig zu erkennen. Änderungen an zentralen Datenobjekten erfolgen ausschließlich über definierte Backend-Schnittstellen, sodass unautorisierte oder inkonsistente Zustände vermieden werden. Ergänzend werden relevante Änderungsereignisse protokolliert, um Manipulationen nachvollziehen und analysieren zu können.

- Festlegung: Datenänderungen nur über kontrollierte Backend-Logik
- Schutz vor direkter Manipulation von Analyse- oder Konfigurationsdaten
- Integritätsprüfungen an sicherheitskritischen Verarbeitungsschritten
- Vermeidung stiller oder inkonsistenter Datenänderungen
- Protokollierung von Änderungen zur späteren Nachvollziehbarkeit
- Mitigation von Manipulationsbedrohungen (TM-T1 / TM-T2)

8.6 SR-6 (Externe Datenquellen)

SR-6 (Externe Datenquellen) wird durch ein kontrolliertes Integrations- und Validierungskonzept umgesetzt, das die sichere Verarbeitung externer Marktdaten gewährleistet. Daten aus externen Schnittstellen werden vor ihrer Weiterverarbeitung systematisch geprüft und validiert, um fehlerhafte, manipulierte oder inkonsistente Informationen zu erkennen. Die Verarbeitung externer Daten erfolgt entkoppelt von der Kernlogik, sodass Störungen oder Auffälligkeiten einzelner Datenquellen nicht unmittelbar die Integrität oder Verfügbarkeit des Gesamtsystems beeinträchtigen.

- Definition eines klaren Integrationspunkts für externe APIs
- Validierung und Plausibilitätsprüfung externer Marktdaten
- Trennung zwischen externer Datenaufnahme und interner Verarbeitung
- Schutz vor manipulierten oder fehlerhaften Drittanbieterdaten
- Reduktion von Kaskadeneffekten bei fehlerhaften API-Antworten
- Umsetzung der in der Analyse identifizierten Risiken externer Abhängigkeiten

8.7 SR-7 (Schnittstellensicherheit)

SR-7 (Schnittstellensicherheit) wird durch ein einheitliches Sicherheitskonzept für alle extern und intern exponierten Schnittstellen umgesetzt. Sämtliche Schnittstellen werden ausschließlich über definierte APIs bereitgestellt und sind durch geeignete Authentisierungs- und Autorisierungsmechanismen abgesichert. Eingehende Anfragen werden vor der Verarbeitung validiert, um fehlerhafte oder manipulierte Daten frühzeitig abzuweisen. Darüber hinaus werden Schutzmaßnahmen implementiert, die eine missbräuchliche Nutzung der Schnittstellen, etwa durch automatisierte Anfragen oder Überlastung, begrenzen.

- Festlegung: Zugriff auf Systemfunktionen nur über definierte APIs
- Absicherung aller Schnittstellen durch Authentisierung und Autorisierung
- Validierung von API-Anfragen (Struktur, Datentypen, Umfang)
- Schutz vor missbräuchlicher Nutzung (z. B. Rate Limiting)
- Vermeidung unkontrollierter oder impliziter Schnittstellen
- Reduktion der Angriffsfläche an Trust Boundaries

8.8 SR-8 (Fehler- und Manipulationserkennung)

SR-8 (Fehler- und Manipulationserkennung) wird durch Mechanismen umgesetzt, die sicherheitsrelevante Abweichungen im Systemverhalten erkennen und kontrolliert behandeln. Auffällige Zustände, wie unerwartete Datenformate, Integritätsverletzungen oder fehlerhafte externe Eingaben, werden erkannt und führen zu einer definierten Fehlerbehandlung. Anstatt potenziell unsichere Daten weiterzuverarbeiten, werden diese verworfen oder isoliert behandelt. Ergänzend werden relevante Ereignisse protokolliert, um eine spätere Analyse und Bewertung sicherheitsrelevanter Vorfälle zu ermöglichen.

- Definition, was als „auffälliges“ oder fehlerhaftes Verhalten gilt
- Erkennung von Manipulations- oder Integritätsverletzungen
- Fail-safe-Verhalten: fehlerhafte Daten werden nicht weiterverarbeitet
- Kontrollierte Fehlerbehandlung statt stiller Akzeptanz
- Protokollierung sicherheitsrelevanter Abweichungen
- Unterstützung von Incident Detection und Analyse

8.9 SR-9 (Verfügbarkeit)

SR-9 (Verfügbarkeit) wird durch Maßnahmen umgesetzt, die einen stabilen und kontrollierten Betrieb des Systems auch unter erhöhter Last oder bei missbräuchlicher Nutzung gewährleisten. Hierzu werden Mechanismen vorgesehen, die eine Überlastung sicherheitskritischer Komponenten verhindern und den Zugriff auf Ressourcen begrenzen. Ziel ist es, die Funktionsfähigkeit des Systems aufrechtzuerhalten und gleichzeitig sicherzustellen, dass sicherheitsrelevante Schutzmechanismen nicht durch Verfügbarkeitsangriffe umgangen werden können.

- Schutz vor Überlastung durch begrenzte Ressourcennutzung
- Vermeidung von Denial-of-Service-Szenarien auf Anwendungsebene
- Priorisierung sicherheitskritischer Funktionen
- Sicherstellung eines kontrollierten Betriebs bei hoher Last
- Umsetzung der Verfügbarkeitsanforderungen aus der Analyse

8.10 SR-10 (Fehlertoleranz)

SR-10 (Fehlertoleranz) wird durch ein robustes Systemdesign umgesetzt, das auch bei Teilfehlern oder dem Ausfall einzelner Komponenten ein definiertes und sicheres Verhalten gewährleistet. Fehlerhafte Zustände führen nicht zu unkontrollierten oder unsicheren Systemzuständen, sondern werden gezielt abgefangen und behandelt. Insbesondere bei Abhängigkeiten von externen Diensten wird sichergestellt, dass Fehler nicht zu einer fehlerhaften Weiterverarbeitung oder zu sicherheitsrelevanten Folgeproblemen führen.

- Definition eines sicheren Standardverhaltens bei Fehlern
- Vermeidung von „Fail-Open“-Zuständen
- Kontrollierte Behandlung von Teil- oder Systemausfällen
- Sicheres Verhalten bei Ausfall externer Abhängigkeiten
- Erhöhung der Robustheit gegen Kaskadeneffekte

8.11 SR-11 (Protokollierung)

SR-11 (Protokollierung) wird durch ein zentrales Logging-Konzept umgesetzt, das sicherheitsrelevante Ereignisse systematisch erfasst und nachvollziehbar macht. Protokolliert werden insbesondere Authentisierungs- und Autorisierungsereignisse, sicherheitsrelevante Fehler sowie administrative Aktionen. Die Protokollierung erfolgt so, dass relevante Ereignisse zeitlich und fachlich korreliert werden können, um die Analyse sicherheitsrelevanter Vorfälle zu unterstützen.

- Definition sicherheitsrelevanter Ereignisse
- Zentrale Erfassung von Logs
- Ermöglichung der Korrelation von Ereignissen
- Unterstützung von Incident Response und Analyse
- Umsetzung der Nachvollziehbarkeitsanforderungen

8.12 SR-12 (Schutz von Protokolldaten)

SR-12 (Schutz von Protokolldaten) wird durch technische und organisatorische Maßnahmen umgesetzt, die die Vertraulichkeit, Integrität und Verfügbarkeit der erzeugten Protokolldaten sicherstellen. Der Zugriff auf Logdaten ist auf einen definierten Personenkreis beschränkt, und unbefugte Änderungen oder Löschungen werden verhindert. Dadurch wird sichergestellt, dass Protokolldaten als verlässliche Grundlage für Audits, Analysen und sicherheitsrelevante Untersuchungen dienen können.

- Einschränkung des Zugriffs auf Logdaten
- Schutz vor Manipulation oder Löschung von Logs
- Sicherstellung der Integrität protokollierter Ereignisse
- Trennung von Betriebs- und Logdaten
- Gewährleistung der Auditierbarkeit

Inhaltsverzeichnis

1 Inhaltsverzeichnisidee **1**

2 Relevanz **5**

3 Motivation **7**

4 Problemraumbeschreibung **8**

5 Epics **10**

5.1 Epic 1: Core Functions 10

5.1.1 FA-1.1 Portfoliomanagement 11

5.1.2 FA-1.2 Marktdaten 12

5.1.3 FA-1.3 Nachrichten & Sentiment 13

5.1.4 FA-1.4 Fundamentalanalyse 14

5.1.5 FA-1.5 Alerts & Benachrichtigungen 15

5.1.6 FA-1.6 Technische Analyse 16

5.1.7 FA-1.7 Quantitative Analyse & Screening 17

5.1.8 FA-1.8 Makro- & Marktumfeld 18

5.2 EPIC 2: User Interface & Interaction Design 19

5.2.1 FA-2.1 Kernflows 20

5.2.2 FA-2.2 Informationsarchitektur 21

5.2.3 FA-2.3 Responsiveness 22

5.2.4 FA-2.4 Charting 23

5.2.5 FA-2.5 Benutzerfreundlichkeit & Performance 24

5.2.6 FA-2.6 Barrierefreiheit & Lesbarkeit 25

5.2.7 FA-2.7 Guided UX 26

5.2.8 FA-2.8 Internationalisierung 27

5.3 EPIC 3: Information Presentation & Risk Communication 28

5.3.1 FA-3.1 Darstellung von Marktdaten & Analysen 29

5.3.2 FA-3.2 Nachrichten- & Sentimentdarstellung 30

5.3.3 FA-3.3 Risikohinweise & Warnmeldungen 31

5.3.4 FA-3.4 Fehlerzustände & Systemmeldungen 32

5.3.5 FA-3.5 Bestätigungs- & Hinweisstufen 33
5.4 EPIC 4: Trust, Transparency & UX-Security 34
5.4.1 FA-4.1 Sicherheit & Vertrauen 35
5.4.2 FA-4.2 Transparenz sicherheitsrelevanter Aktionen 36
5.4.3 FA-4.3 Auditierbarkeit aus Nutzersicht 37
5.4.4 FA-4.4 Feature- & Zugriffstransparenz 38
5.4.5 FA-4.5 Personalisierung & Sichtbarkeit von Sicherheitsfunktionen 39
5.5 EPIC 5: Platform Security & Access Control 40
5.5.1 FA-5.1 Authentifizierung 41
5.5.2 FA-5.2 Autorisierung & Rollenmodelle 42
5.5.3 FA-5.3 Sitzungs- & Zugriffssicherheit 43
5.5.4 FA-5.4 Schnittstellensicherheit 44
5.5.5 FA-5.5 Missbrauchs- & Angriffsschutz 45
5.5.6 FA-5.6 Protokollierung & Sicherheitsüberwachung 46

6 Einordnung des Projekts in den Secure Software Development Lifecycle (SSDLC) 47

7 Analyse 49
7.1 Security Requirements Engineering: 49
7.1.1 Security Goals (übergeordnete Sicherheitsziele) 50
7.1.2 Bedrohungsanalyse (Threats) 51
7.1.3 Abgeleitete Security Requirements (Kernstück) 52
7.2 Threat Modeling: 54
7.3 Abgrenzung & Annahmen 54
7.3.1 Systemgrenzen 54
7.3.2 Trust Boundaries 54
7.3.3 Angreiferprofile 55
7.3.4 STRIDE-Analyse 56
7.3.5 Konsolidierte Threat-Liste 57
7.3.6 Traceability zwischen Bedrohungen, Security Requirements und Sicherheitszielen 60

8 Design 63

8.1 SR-1 (Authentisierung) 63
8.2 SR-2 (Autorisierung) 64
8.3 SR-3 (Schutz personenbezogener Daten) 65
8.4 SR-4 (Zweckbindung und Datenminimierung) 66
8.5 SR-5 (Datenintegrität) 67
8.6 SR-6 (Externe Datenquellen) 68
8.7 SR-7 (Schnittstellensicherheit) 69
8.8 SR-8 (Fehler- und Manipulationserkennung) 70
8.9 SR-9 (Verfügbarkeit) 71
8.10 SR-10 (Fehlertoleranz) 72
8.11 SR-11 (Protokollierung) 73
8.12 SR-12 (Schutz von Protokolldaten) 74